Global Cyber Incident Response & Ransomware Playbook

Document ID: SOP-IR-09-EN | Version: 4.0 | Clearance: Restricted (Min. Role L2) | Region: Global / DACH

15 Minuten	36 Stunden	0 EUR (No Pay)
SOC TRIAGE & ISOLATION SLA	BSI EARLY WARNING (SOP-IR)	RANSOMWARE EXTORTION POLICY

§ 1 Scope, Incident Classification & CSIRT Activation

This Standard Operating Procedure (SOP-IR-09) governs the detection, containment, forensic investigation, and regulatory reporting of severe cyber security incidents (Sicherheitsvorfälle), specifically targeted ransomware attacks, Active Directory compromises, and confirmed data exfiltration across all group subsidiaries. Any suspected ransomware execution or unauthorized mass encryption automatically triggers a **Severity 1 (Critical Emergency / Krise)** classification. Upon detection by Endpoint Detection and Response (EDR) or the Security Operations Center (SOC), the Incident Commander must convene the Computer Security Incident Response Team (CSIRT) within **15 Minuten** (15 minutes).

§ 2 Regulatory Reporting Timelines (NIS-2, GDPR & BSI Meldefristen)

All external regulatory notifications must be coordinated exclusively by the CISO Office and Legal Counsel. Under this global playbook, the following mandatory reporting deadlines (Meldefristen) apply for significant security incidents (erhebliche Sicherheitsvorfälle):

- **Internal Escalation to CISO Office:** Immediately, and no later than **30 Minuten** after initial SOC alert validation.
- **NIS-2 Early Warning to National CSIRT / BSI (Frühwarnung):** Within **36 Stunden** (36 hours) of becoming aware of the significant incident. *(Note: Group international buffer applied; deviates from 24 Stunden DACH national rules).*
- **Formal NIS-2 Incident Notification (Vorfallmeldung):** Within **96 Stunden** (96 hours) after initial awareness, including indicators of compromise (IoCs) and root cause assessment.
- **GDPR Data Breach Notification (DSGVO Art. 33 Datenschutzbehörde):** Within **72 Stunden** (72 hours) if personal data of customers or employees has been exfiltrated.
- **Final Post-Incident Report (Abschlussbericht):** Within **30 Tage** (1 Monat) after submission of the formal incident notification.

§ 3 Ransomware Containment, Recovery & RACI Matrix

During an active ransomware outbreak, preserving volatile memory (RAM) and preventing lateral movement across network segments takes precedence over immediate system rebooting. Affected hosts must be isolated at the EDR and switch-port level, never powered off via hard reset before forensic volatile capture.

Incident Phase & Action	Target SLA	Responsible (R)	Accountable (A)	Consulted / Informed
1. Host & VLAN Isolation	**15 Minuten**	SOC Analyst / L2 Admin	CISO	Network Team (C), IT Head (I)
2. Volatile RAM & Log Capture	**2 Stunden**	DFIR Forensics Lead	Incident Commander	CISO (C), Legal Counsel (I)
3. AD Krbtgt Double-Reset	**4 Stunden**	Tier-0 Identity Admin	IT Infrastructure Lead	CISO (A/C), All Staff (I)
4. Tier 1 Clean Room Restore	**6 Stunden**	Backup & Recovery Team	IT Infrastructure Lead	Business Owners (C/I)

§ 4 Forensic Evidence Retention & Strictly Prohibited Ransom Payments

All forensic disk images, memory dumps, firewall flow logs, and SIEM telemetry related to a Severity 1 or Severity 2 cyber incident must be stored on immutable Write-Once-Read-Many (WORM) storage in a cryptographically hashed evidence vault (SHA-256 chain of custody) for a minimum retention period of **3 Jahre** (36 Monate).

Strict No-Ransom Policy (Erpressungsverbot): The company strictly prohibits the payment of any ransom (Lösegeld) or cryptocurrency extortion demands to threat actors. No employee, executive, or external negotiator is authorized to transfer funds to ransomware groups, as payments violate international sanctions lists and do not guarantee decryption or data deletion. Restoration must exclusively utilize immutable offline backups (Air-Gapped / Object-Lock Repositories).

> **Cross-Document Governance Warning (NIS-2 / BCM Alignment):** Section 2 of this global playbook specifies a **36 Stunden** (36-hour) early warning window and a **96 Stunden** (96-hour) formal notification deadline, whereas Section 3 specifies a **6 Stunden** Tier 1 restore target. When staging this document in DACH jurisdictions, the CISO must resolve the conflict against *bcm_notfallhandbuch_2026.pdf* (24 Stunden / 72 Stunden / 4 Stunden RTO) and *NIS2_Incident_Playbook.md* (12 Stunden Frühwarnung).